

OFFENSIVE IDS OVERVIEW

VERSION: 1.4a
DATE: 27/02/2019
AUTHOR: SYLVAIN MARTINEZ
REFERENCE: ESC14-MUSCL
CLASSIFICATION: PUBLIC



CONTENTS

CONTEXT

- IDS Introduction;
- Topology Example;
- IDS Benefits;

CONCEPT

- Offensive IDS Overview;
- Topology Revisited;
- Benefits Revisited;

SETUP

- Capturing traffic;
- Core Components;
- Tweaking;

USE CASES

- Finding the needle;
- Free credentials;
- IDS Dashboard example;

BEYOND

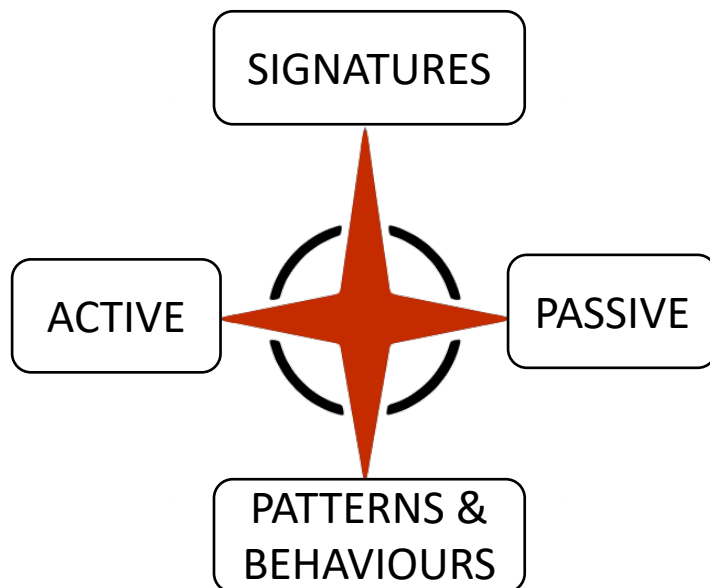
- Not just defence;
- Resources.

IDS INTRODUCTION

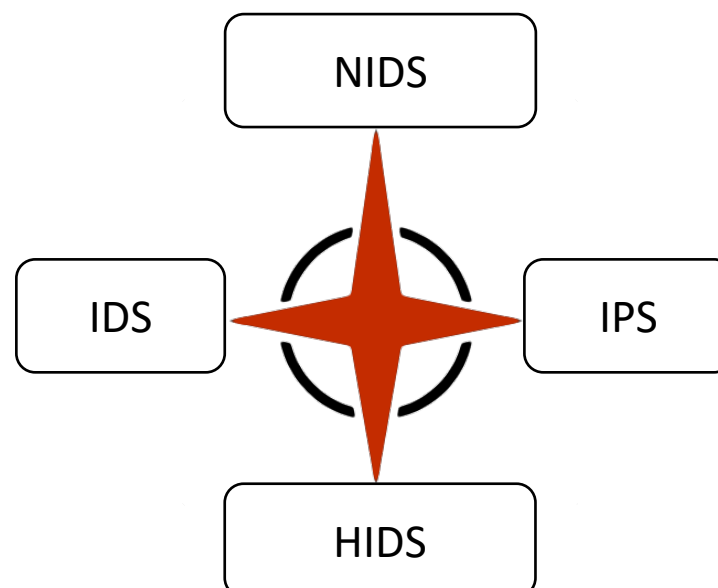
IDS HIGH LEVEL CONCEPT



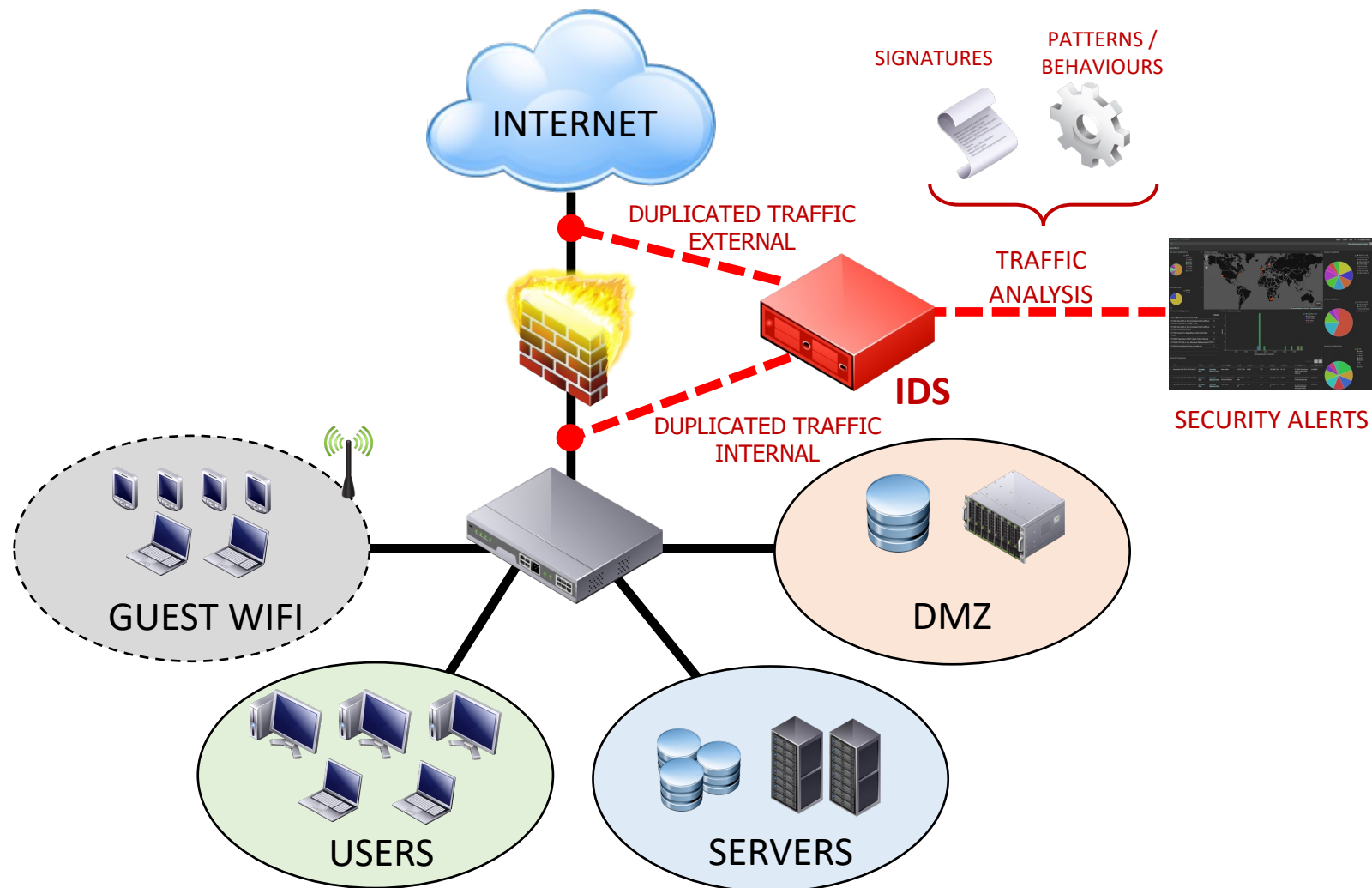
ANALYSIS OPTIONS



CONFIGURATION OPTIONS



TOPOLOGY EXAMPLE



IDS MAIN BENEFITS

ALERTS

CYBER SECURITY ATTACKS ALERTS

(PORT SCANS, C2C, BRUTE FORCE, ETC)

CYBER SECURITY ISSUES ALERTS

(CLEAR TEXT PASSWORD, OUTDATED APP, ETC)

VULNERABLE HOSTS ALERTS

(CVE, EXPLOITS, ETC.)

VULNERABLE APPLICATIONS ALERTS

(CVE, EXPLOITS, ETC.)

INVESTIGATION

NETWORK ACTIVITY VIEW

(IP SOURCE & DESTINATION, PORTS, PROTOCOLS)

NETWORK DATA FLOW VIEW

(NETWORK ENTITY RELATIONSHIPS)

NETWORK ANOMALIES VIEW

(SUSPICIOUS TIMELINE, ACTIVITY SPIKES & VOLUME)

NETWORK CONTENT VIEW

(HTTP, FTP, SMB, ETC.)

OFFENSIVE IDS OVERVIEW



GOAL

TO USE THE POWER OF IDS TO HELP FIND INTERESTING TIMELINE, VULNERABILITIES AND SENSITIVE DATA



HOW

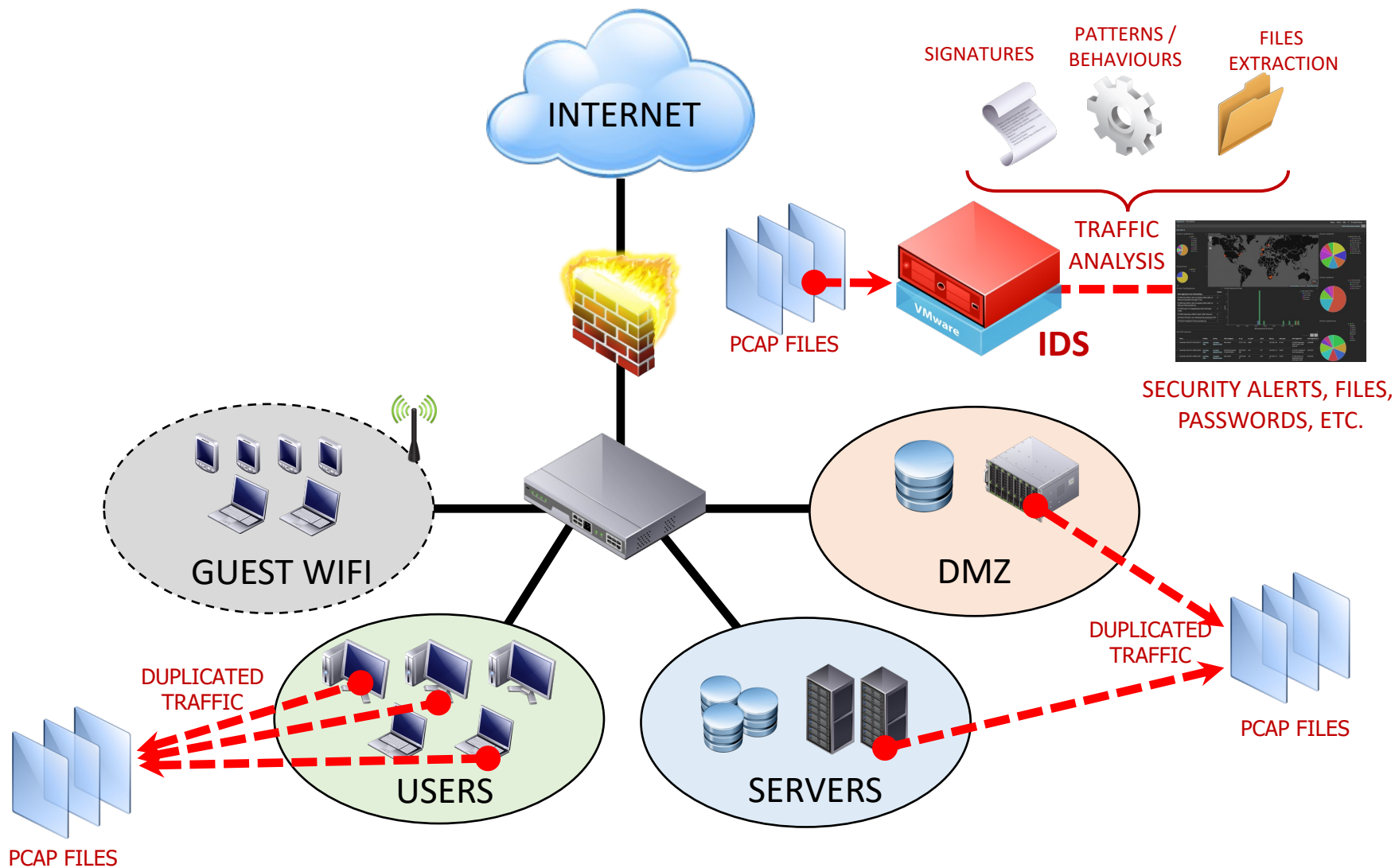
CAPTURING TRAFFIC AND EVENTS IN A PCAP FILE AND REPLAY IT INTO A STANDALONE IDS IN A VM



WHY

TO HELP GOING THROUGH LARGE VOLUME OF CAPTURED DATA AND RE-PURPOSE THE BENEFITS OF IDS

NETWORK TOPOLOGY - REVISITED



IDS MAIN BENEFITS - REVISITED

CYBER SECURITY ATTACKS ALERTS

(PORT SCANS, C2C, BRUTE FORCE, ETC)

CYBER SECURITY ISSUES ALERTS

(CLEAR TEXT PASSWORD, OUTDATED APP, ETC)

VULNERABLE HOSTS ALERTS

(CVE, EXPLOITS, ETC.)

VULNERABLE APPLICATIONS ALERTS

(CVE, EXPLOITS, ETC.)

NETWORK ACTIVITY VIEW

(IP SOURCE & DESTINATION, PORTS, PROTOCOLS)

NETWORK DATA FLOW VIEW

(NETWORK ENTITY RELATIONSHIPS)

NETWORK ANOMALIES VIEW

(SUSPICIOUS TIMELINE, ACTIVITY SPIKES & VOLUME)

NETWORK CONTENT VIEW

(HTTP, FTP, SMB, ETC.)

SPEED UP NETWORK TRAFFIC ANALYSIS

IDENTIFY INTERESTING TIMELINES

IDENTIFY VULNERABILITIES TO EXPLOIT

IDENTIFY TARGETS OF INTEREST

EXTRACT SENSITIVE INFORMATION

PROFILE USERS AND APPLICATIONS

PHYSICAL ACCESS REQUIRED IN MOST CASES

TAP TRAFFIC AGAINST KEY TARGETS

POWERED/UNPOWERED SOLUTIONS

DUMMY CAPTURE DEVICES:

- SMALL ROUTER;
- THROWING STAR LAN;

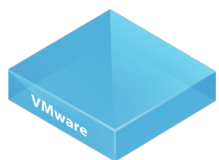
INTELLIGENT CAPTURE DEVICES:

- RASPBERRY PI;
- HAK5 PACKET SQUIRREL.



**NO OPERATIONAL
IMPACT**





VIRTUAL MACHINE

USE A FREE IDS DISTRIBUTION SUCH AS SECURITY ONION OR SELKS
SET IT UP AS A STANDALONE VM



IDS ENGINE

DECIDE WHICH ENGINE TO USE: SURICATA OR SNORT



REPLAY TRAFFIC

USE TCPREPLAY
YOU CAN ACCELERATE IF YOU DON'T MIND ABOUT TIMELINE.

LOOPBACK NIC DOES NOT WORK WITH TCPREPLAY ON A VM

USE A DUMMY NIC INSTEAD

CONFIGURE YOUR IDS TO MONITOR THAT NIC

```
#!/bin/sh
# ELYSIUMSECURITY - https://www.elysiumsecurity.com
# Version 2.0
sudo modprobe dummy
sudo ip link set name ens84 dev dummy0
sudo ifconfig ens84 up
echo ens84 created and up
echo now edit /etc/suricata/suricata.yaml and replace all eth0 with ens84
echo also enable file-store, waldo file, change stream.reassembly.depth
echo and edit suricata/rules/files.rules to enable: Simply store all files we encounter
echo
echo You may need to fix suricata if not working:
echo tail /var/log/suricata/suricata.log
echo service suricata stop
echo rm /var/run/suricata.pid
echo service suricata start
echo
echo you can then do a tcpreplay such as:
echo tcpreplay -i ens84 -M10 your.pcap
echo
```

FINDING THE NEEDLE



SCENARIO

- FIND THE SECRET CONTRACT XYZ
- YOU ARE ONLY GIVEN 3 EMPLOYEES NAME



CHALLENGES

- 50GB OF INTERCEPTED TRAFFIC OVER A WEEK PERIOD
- YOU DON'T KNOW WHERE TO LOOK
- WIRESHARK DOESN'T LIKE THAT FILE SIZE SO MUCH...



IDS TO THE RESCUE

- REPLAYED THE 50GB OF DATA TO A STANDALONE IDS
- ABLE TO PINPOINT DAYS AND TIME OF PEAK ACTIVITY AND TYPE OF ACTIVITY (FILE TRANSFER)
- GO BACK TO WIRESHARK WITHIN A MUCH SMALLER TIMEFRAME AND FIND THE DOCUMENT!



SCENARIO

- ACCESS THE ACCOUNT OF A TOP EXECUTIVE



CHALLENGES

- THE EXECUTIVE IS PARANOID AND DID NOT FALL FOR PHISHING
- THE EXECUTIVE IS VERY CAREFUL WITH HER SOCIAL MEDIA PRESENCE
- HER LAPTOP IS FULLY PATCHED
- NETWORK TRAFFIC INTERCEPTED IS TOO BIG TO BE USEFUL



IDS TO THE RESCUE

- REPLAYED NETWORK TRAFFIC TO A STANDALONE IDS
- ALERT FOR A PASSWORD SENT IN CLEAR TEXT
- THE EXECUTIVE IS UPDATING A CHARITY BLOG USING AN ALIAS
- SHE USES THE SAME PASSWORD ON HER CORPORATE ACCOUNT

IDS DASHBOARD EXAMPLE

Dashboard / BUGS ALERTS

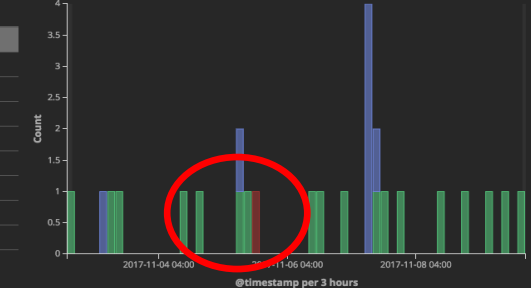
Share Clone Edit 30 seconds Last 7 days

Add a filter +

BUGS - Alert-Top20Signatures

alert.signature.raw: Descending	Count
ET DROP Spamhaus DROP Listed Traffic Inbound	7
ET TOR Known Tor Relay/Router (Not Exit) Node Traffic	6
ET POLICY Outdated Flash Version M1	5
GPL CHAT Jabber/Google Talk Outgoing Traffic	5
ET POLICY Possible IP Check api.lipify.org	1
ET SHELLCODE Common Database Heap Spray String	1
ET WEB_CLIENT Obfuscated Javascript // ptt	1

BUGS - Alert-ByExtraInfoType



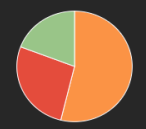
BUGS - Alert-GeoMap



SN Alert-Count



BUGS Alert-Severity



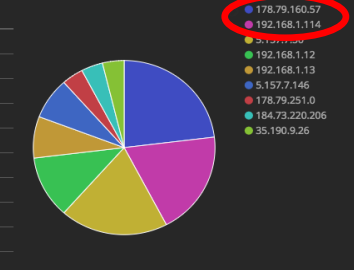
BUGS - DNS - LATEST

dns.rname.raw: Descending	Min @timestamp
tiles.maps.elastic.co	November 9th 2017, 19:42:57.147
catalogue.maps.elastic.co	November 9th 2017, 19:42:55.469
api.lipify.org	November 9th 2017, 19:42:41.350
viewposzddgzojz	November 9th 2017, 19:41:36.378
awarroyist	November 9th 2017, 19:41:36.378
ndbkmp	November 9th 2017, 19:41:36.378
apis.google.com	November 9th 2017, 19:41:29.347
onedclient.sfx.ms.edgekey.net	November 9th 2017, 19:39:47.142
e9659.dspg.akamaiedge.net	November 9th 2017, 19:39:47.142
3.courier-sandbox-push-apple.com.akadns.net	November 9th 2017, 19:39:45.793

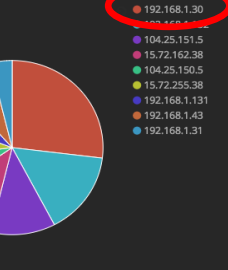
BUGS - HTTP LATEST

http.hostname.raw: Descending	Min @timestamp
ocsp2.globalsign.com	November 9th 2017, 14:17:20.910
www.airfrance.fr	November 9th 2017, 14:17:14.588
content.infos-airfrance.com	November 9th 2017, 14:17:14.010
email.airmauriltus.com	November 9th 2017, 14:13:17.582
ic.c5e23b00.088a44.gs2.sonycoment.loris-e.llnwd.net	November 9th 2017, 13:27:10.113
ic.c5e23b00.06fa54.gs2.sonycoment.loris-e.llnwd.net	November 9th 2017, 13:26:57.433
www.youmags.net	November 9th 2017, 13:23:14.170
scm.st	November 9th 2017, 13:23:12.941
gs2.wv.procdi.playstation.net	November 9th 2017, 13:16:10.906
tmdb.np.dl.playstation.net	November 9th 2017, 13:16:09.799

SN Alert-Top20SrcIP



SN Alert-Top20DstIP



BUGS ALERT-EventsList

Time	alert.category	src_ip	dest_ip	http.hostname	alert.signature	SrcIris	EveBox
November 9th 2017, 19:04:01	Misc Attack	5.157.7.50	192.168.1.30	-	ET DROP Spamhaus DROP Listed Traffic Inbound	Complete Signature View	Correlate Flow
November 9th 2017, 13:33:11	Misc Attack	5.157.7.50	192.168.1.30	-	ET DROP Spamhaus DROP Listed Traffic Inbound	Complete Signature View	Correlate Flow
November 9th 2017, 08:25:31	Misc Attack	5.157.7.50	192.168.1.30	-	ET DROP Spamhaus DROP Listed Traffic Inbound	Complete Signature View	Correlate Flow
November 8th 2017, 22:46:44	Misc Attack	178.79.160.57	192.168.1.132	-	ET TOR Known Tor Relay/Router (Not Exit) Node Traffic	Complete Signature View	Correlate Flow
November 8th 2017, 14:33:21	Not Suspicious Traffic	192.168.1.114	15.72.162.38	-	GPL CHAT Jabber/Google Talk Outgoing Traffic	Complete Signature View	Correlate Flow
November 7th 2017, 23:05:51	Misc Attack	5.157.7.50	192.168.1.30	-	ET DROP Spamhaus DROP Listed Traffic Inbound	Complete Signature View	Correlate Flow
November 7th 2017, 17:45:21	Misc Attack	178.79.160.57	192.168.1.132	-	ET TOR Known Tor Relay/Router (Not Exit) Node Traffic	Complete Signature View	Correlate Flow
November 7th 2017, 14:33:11	Not Suspicious Traffic	192.168.1.114	15.72.162.38	-	GPL CHAT Jabber/Google Talk Outgoing Traffic	Complete Signature View	Correlate Flow
November 7th 2017, 12:39:41	Potential Corporate Privacy Violation	192.168.1.12	104.25.150.5	www.youneedabudget.com	ET POLICY Outdated Flash Version M1	Complete Signature View	Correlate Flow
November 7th 2017, 11:46:41	Potential Corporate Privacy Violation	192.168.1.12	104.25.151.5	www.youneedabudget.com	ET POLICY Outdated Flash Version M1	Complete Signature View	Correlate Flow
November 7th 2017, 11:43:01	Potential Corporate Privacy Violation	192.168.1.13	104.25.151.5	www.youneedabudget.com	ET POLICY Outdated Flash Version M1	Complete Signature View	Correlate Flow
November 7th 2017, 11:38:01	Potential Corporate Privacy Violation	192.168.1.13	104.25.150.5	www.youneedabudget.com	ET POLICY Outdated Flash Version M1	Complete Signature View	Correlate Flow

DETECT

ALERT

INVESTIGATE

ATTACK

IDS ENVIRONMENT, LIKE MOST SECURITY DEFENSE TOOLS ENVIRONMENT, CONTAINS SENSITIVE DATA AND MUST BE PROTECTED SO THEIR INFORMATION IS NOT USED AGAINST YOU!

SNORT BASED ENGINE: [HTTPS://WWW.SNORT.ORG/](https://www.snort.org/)

SURICATA BASED ENGINE: [HTTPS://SURICATA-IDS.ORG/](https://suricata-ids.org/)

IDS VIRTUAL MACHINE DISTRIBUTION

- SECURITY ONION (SO): [HTTPS://SECURITYONION.NET/](https://securityonion.net/)
- SELKS: [HTTPS://WWW.STAMUS-NETWORKS.COM/OPEN-SOURCE/](https://www.stamus-networks.com/open-source/)

VARIOUS INSTALL GUIDE AVAILABLE:

[HTTPS://WWW.ELYSIUMSECURITY.COM/BLOG/GUIDES/POST7.HTML](https://www.elysiumsecurity.com/blog/guides/post7.html)

GREAT COMMUNITY IS HERE TO HELP;

SO AND SELKS AUTHORS ARE VERY ACTIVE;

PROFESSIONAL SUPPORT AVAILABLE FROM THEM TOO;

ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDiate** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

